

ICS 03.060

CCS A 11

JR

中华人民共和国金融行业标准

JR/T 0358—2026

金融数据安全 数据安全能力体系

Financial data security—Data security capability system

2026-6-6 发布

2026-6-6 实施

中国人民银行

发布

目 次

前 言 II

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 数据安全能力体系 1

5 通用数据安全保障 4

6 数据分类分级管理 5

7 数据生命周期安全 6

8 数据安全运营保障 13

参 考 文 献 20

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国人民银行科技司提出。

本文件由全国金融标准化技术委员会（SAC/TC 180）归口。

本文件起草单位：中国工商银行股份有限公司、中国农业银行股份有限公司、中国银行股份有限公司、中国建设银行股份有限公司、中国邮政储蓄银行股份有限公司、中国金融电子化集团有限公司、网联清算有限公司、北京银联金卡科技有限公司、中国银联股份有限公司、中信银行股份有限公司、浙商银行股份有限公司、恒丰银行股份有限公司、华夏银行股份有限公司、广发银行股份有限公司、北京银行股份有限公司、南京银行股份有限公司、四川银行股份有限公司、泉州银行股份有限公司、河北银行股份有限公司、日照银行股份有限公司、北京农村商业银行股份有限公司、广东南海农村商业银行股份有限公司、浙江网商银行股份有限公司、财付通支付科技有限公司、支付宝支付科技有限公司。

本文件主要起草人：任文冲、孙丽君、陈璐、赵志蛟、李硕、李晓龙、刘俊婷、庞家锋、陈雪秀、高鑫、李景丹、陈川川、林宇、高强裔、于柳婧、唐辉、谢彦丽、刘昭洁、张晋钰、韩竺吾、王爱玲、周迪、翁芳雨、陈聪、张艳君、田鑫、杨溢、杨杨、夏一凡、孙钢、钱正旸、刘海龙、王艺铮、时思琦、杨珉、曾立环、李欣、毕家瑞、张文嘉、吴迪、陈轶、余小明、秦曾、盛普、耿亚娟、汪峰、许晓东、孙雪、宋新宇、林俊浩、姜春颖、张园超、谢宗华、程虎、王程、吴永强、白晓媛、聂正军。

金融数据安全 数据安全能力体系

1 范围

本文件提出了金融数据安全能力体系，包括通用数据安全保障、数据分类分级管理、数据生命周期安全及数据安全运营保障4个能力域，从组织建设、制度流程、技术能力及人员能力4个能力维度，将金融从业机构数据安全能力由低到高划分为一至五级，明确了各能力域建设目标及对应等级的能力要求。

本文件适用于金融从业机构数据安全能力体系的规划、建设、评估等工作。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 37988—2019 信息安全技术 数据安全能力成熟度模型

3 术语和定义

GB/T 37988—2019界定的以及下列术语和定义适用于本文件。

3.1

数据安全能力 data security capability

金融从业机构通过优化组织结构、完善制度规程、健全管理流程、应用工具、提升人员意识与技能等方式，形成系统化、可持续建设和改进的数据安全保障体系。

[来源：GB/T 37988—2019，3.5，有修改]

3.2

数据安全能力域 area of data security capability

数据安全能力体系中，实现同一数据安全目标的数据安全相关活动的集合。

[来源：GB/T 37988—2019，3.9，有修改]

注：一个能力域包含一个或多个数据安全相关活动，且这些活动可分类归纳为一个或多个数据安全能力子域。

4 数据安全能力体系

4.1 能力体系的构成

数据安全能力体系见图1，包含数据安全能力域、数据安全能力维度和数据安全能力等级，具体描述如下。

- a) 数据安全能力域明确金融从业机构数据安全能力，包括通用能力和专项能力，具体如下。
 - 通用能力是通用性和普适性的数据安全保障能力，覆盖金融从业机构开展日常数据安全工作的基本要求，是数据安全体系化管理的前提条件和机制基础。
 - 专项能力是专用性和差异性的数据安全保障能力，包括数据分类分级管理、数据生命周期安全、数据安全运营保障等，是在通用能力的基础上，适应于具体数据安全工作过程和特定应用场景的数据安全措施细化和体系延展。
- b) 数据安全能力维度描述金融从业机构在组织建设、制度流程、技术能力及人员能力4个方面应具备的能力。

c) 数据安全能力等级从低到高划分为一至五级，用于衡量金融从业机构数据安全建设的体系化程度、制度执行力、防护有效性、安全状态可持续性等整体数据安全能力，等级越高代表机构数据安全工作的系统性、有效性、可靠性和可持续性程度越高。

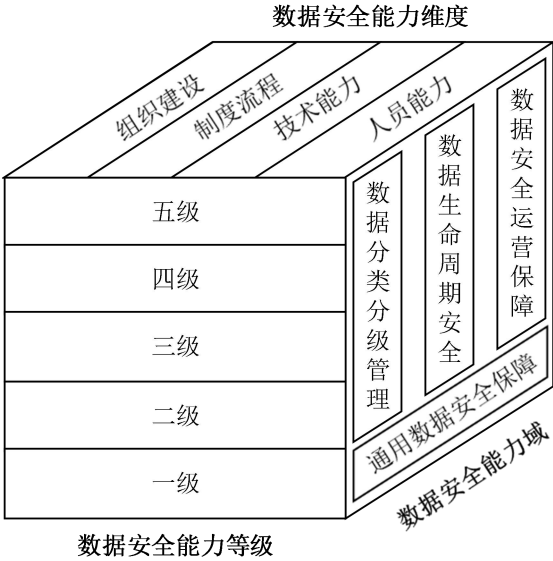


图1 数据安全能力体系

4.2 数据安全能力域

数据安全能力域见表1。金融从业机构应在通用能力建设基础上，结合数据应用场景及数据安全工作策略，按照专项能力子域要求建设专项能力，同时宜结合自身数据安全工作特点，自行细化和增补有关专项能力子域的特性化要求。

表 1 数据安全能力域

序号	能力分类	能力域	能力子域
1	通用能力	通用数据安全保障	/
2		数据分类分级管理	/
3		数据生命周期安全	数据收集
4			数据存储
5			数据传输
6			数据使用
7			数据加工
8			数据提供
9			数据委托处理
10			数据公开披露
11			数据删除
12			数据销毁
13		数据安全运营保障	权限安全管理
14			数据备份与恢复
15			新技术应用风险防控
16			数据安全风险监测
17			数据安全风险评估
18			数据安全合规审计
19			应急响应与事件处置

4.3 数据安全能力维度

4.3.1 组织建设

从金融从业机构应具备的数据安全组织结构、职责分工等角度，根据以下方面进行能力等级区分。

- a) 数据安全组织结构与本机构管理策略及业务特点适配程度。
- b) 数据安全岗位设置及职责分工的适当程度和明确程度。
- c) 数据安全组织职能和义务的履行程度。

4.3.2 制度流程

从金融从业机构在数据安全制度流程的建设情况、执行情况等角度，根据以下方面进行能力等级区分。

- a) 数据安全相关制度的合规程度、对本机构数据安全需求的覆盖程度和有效程度。
- b) 数据安全相关制度与本机构管理体系、技术体系及业务特点的适配程度。
- c) 数据生命周期全过程数据处理活动授权、审批等流程的适当程度和明确程度。
- d) 数据安全相关制度流程制定、发布、修订、废止等工作程序的健全程度和规范程度。
- e) 数据安全相关制度流程在实际执行中的一致程度和有效程度。

4.3.3 技术能力

从金融从业机构数据安全相关安全技术、应用系统、组件/服务等技术应用情况的角度，根据以下方面进行能力等级区分。

- a) 技术能力对数据安全管理制度及操作规程的标准化、自动化、智能化支持程度。
- b) 技术能力对数据安全技术落地的有效性、自动化、智能化支持程度。
- c) 技术能力在数据生命周期全过程安全防护中的普及程度和有效程度。
- d) 技术能力对本机构数据安全风险评估、监测及应对处置能力的支持程度。

4.3.4 人员能力

从金融从业机构数据安全工作人员管理能力与技术水平的角度，根据以下方面进行能力等级区分。

- a) 人员的数据安全技能与本机构数据安全工作目标的适配程度。
- b) 人员对数据安全相关法律、行政法规、内部管理制度、理论知识体系，及本机构、部门、岗位相关业务和技术的掌握程度。
- c) 人员配备数量的充足程度及人员培养计划的适配程度。
- d) 人员数据安全意识教育及技能培训的有效程度。

4.4 数据安全能力等级

金融从业机构数据安全能力等级由低到高分为一至五级，各级均应覆盖组织建设、制度流程、技术能力、人员能力4个维度能力域的能力要求。

- a) 等级一：数据安全工作处于随机、无序和被动执行状态，通常根据临时需求建立、执行临时数据安全管理制度和流程，数据安全建设高度依赖个人经验且无法广泛复制。
- b) 等级二：数据安全工作在关键和重要业务系统或应用场景处于有计划、有序、主动执行状态，通常依据数据安全管理制度流程或管理要求执行数据安全工作，但未形成整体性和系统性的数据安全工作机制。
- c) 等级三：数据安全工作处于制度化和体系化状态，通常依据数据安全组织结构、专项制度和流程执行数据安全工作，实现数据安全的规范化管理且可广泛复制。
- d) 等级四：数据安全体系处于安全目标和任务可量化评价状态，并动态更新和调整数据安全建设规划及数据安全能力提升工作机制。
- e) 等级五：数据安全体系处于持续自我改进和完善的闭环管理状态，并依据数据安全整体战略、目标、规划、实施效果等情况，进行数据安全相关组织、制度、流程、防护机制等需求和策略的自动识别评价和优化调整。

4.5 能力体系的应用

金融从业机构应参照本文件能力体系要求，建立、保持和改进本机构数据安全保障工作能力，具体应用方法如下。

- a) 数据安全能力体系应用：金融从业机构在实践中应遵循由低到高逐级建设和逐级提升的原则，各能力等级均应具备低一等级的能力要求，并在此基础上新增高等级具有的能力要求。其中，各能力域等级能力说明表中能力等级为“一”的，应将“一”视为默认沿用该维度低一等级能力要求。例如，表3“数据分类分级管理能力域各等级能力说明”中“制度流程”维度等级四为“一”，即默认满足该维度等级三对应的能力要求。
- b) 专项能力的能力域应用：金融从业机构应在符合通用数据安全保障能力域要求的基础上，达到专项能力域相关要求，并在能力建设实践中体现对各专项能力子域的覆盖。其中，各能力域等级能力说明表中能力维度为“一”的，则默认其既符合通用数据安全保障能力域对应等级的能力要求，又沿用该专项能力域低一等级的能力要求。例如，表5“数据存储安全子域各等级能力说明”中“组织建设”维度等级五为“一”，即需同时满足通用能力域“组织建设”维度等级五要求，以及该专项能力子域“组织建设”维度等级四对应的能力要求。

5 通用数据安全保障

5.1 目标

金融从业机构通过构建和完善数据安全相关组织结构、岗位职责、制度规程、技术体系、人员配置等方面工作机制，明确本机构数据安全相关内设部门职责分工、岗位角色和人员分配、策略和规划设计、审批流程设定、技术应用方式、操作规程执行等工作部署，形成科学、系统、全面的数据安全管控体系，防范因策略、制度、技术等管理机制和防护措施的体系漏洞、策略缺失、使用不当或资源不足等问题造成的整体性、系统性数据安全风险。

5.2 能力要求

通用数据安全保障能力域各等级能力说明见表2。

表2 通用数据安全保障能力域各等级能力说明

数据安全能力等级	能力维度	制度流程	技术能力	人员能力
等级一	组织建设 临时组建工作组、设立岗位或指派人员开展数据安全工作。	临时制定数据安全相关工作计划、人员管理规范、安全防护策略等管理要求。	采用电子化方式记录数据处理活动，采用技术措施实现基本权限管控、终端安全防护、数据加密、数据脱敏、日志留存等数据安全保护。	了解我国数据安全相关法律、行政法规、部门规章、技术标准等基本常识，了解本机构数据安全情况，掌握本机构数据安全工作要求和方法。
等级二	配备一定数量的数据安全岗位和人员，负责日常数据安全管理工作、保护、风险监测。	具备统一的数据安全工作要求，针对关键和重要业务系统或应用场景明确数据安全工作目标与建设规划、数据分类分级、数据生命周期全过程安全防护、第三方合作机构管理、数据安全风险监测、人员培训与考核等相关规定。	采用应用/系统安全配置、安全组件/服务等技术措施，实现权限管控、终端防护、数据加密、数据脱敏、审计等安全机制，实现数据收集、数据存储、数据传输、数据使用、数据加工、委托处理等各类数据处理活动的安全管理，在高风险数据处理场景中，具备数据安全防护技术能力。	掌握我国数据安全相关法律、行政法规、部门规章、技术标准，掌握本机构数据资源及数据安全管理情况，熟悉本机构数据安全管理制度流程，具备落地实施能力。
等级三	具备明确的数据安全工作归口管理部门与责任人，形成覆盖本机构“业务管理、合规控制、内部审计”风险防控体系的数据安全管理架构，明确数据资源管理、数据生命周期全过程安全管理、第三	具备涵盖数据安全总体规划、制度规范、实施细则、操作规程等方面的数据安全管理制度体系，具备基于数据分类分级、适配不同场景的数据加密、数据脱敏等安全管理细则和操作规程，明确数据使用、数据加工、数据提供、数据委	采用动态数据脱敏、动态授权、数据水印、多因素认证等多种技术措施、专业设备、应用软件、组件/服务等工具，实现统一的覆盖数据生命周期全过程的数据安全防护技术架构，实现基于数据分类	掌握本机构数据安全管理制度、操作规程与技术要求，具备根据相应要求持续推进和完善本机构数据安全管理体系与工具的能力，具备较强的数据安全合规管理和数据安全技术能力，有效执行本机构数

表2 通用数据安全保障能力域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级三	方合作机构管理、数据安全技术与建设与管理、数据安全运营相关工作职责部门与责任分工，配备与本单位业务、数据规模相适应的数据安全管理团队和人员。	托处理、数据公开披露、新技术应用、第三方合作机构管理、数据安全风险评估等工作要求、管控措施和实施流程，具备数据安全相关培训、考核、评价、问责、激励等机制。	分级、适配不同场景的数据安全防护技术管控，具备相关安全防护策略及安全防护技术应用的一致性管控能力。	据安全要求，具备机构内跨领域、跨部门的统筹协调能力，能够推动安全管理、技术配套、风险防控、事件处置、安全审计等管控措施和机制建设。
等级四	具备体系化的数据安全管理体系，形成覆盖数据生命周期全过程安全防护、数据安全风险控制、数据安全合规审计等职能及岗位配套的精细化管理架构。	具备覆盖数据安全决策、安全管理、技术实施及安全审计全过程的数据安全制度闭环管理机制，具备数据安全管理制度体系落地应用效果量化评价机制和动态调整机制，具备制度变更有效性、及时性等评价机制，具备数据安全需求与业务、技术全面融合的管理机制及评价体系。	具备系统化、自动化管控技术体系，实现数据分类分级、数据安全防护策略及数据安全管控措施自动匹配联动，具备专业化、体系化的数据安全风险监测与数据安全事件响应处置能力。	熟练掌握我国数据安全相关法律法规、行政法规、部门规章、技术标准，能够深度解读有关领域规范要求，具备主导有关领域规范或技术标准编制能力，熟悉金融行业数据安全实践、工具与控制措施，具备数据安全整合方案设计能力，具备设计本机构数据安全整体规划或技术架构能力，能够分析和预判本机构数据安全风险态势及发展路径，为本机构数据安全体系建设、优化提供前瞻性、建设性意见或解决方案，具备对自动化配置或推荐策略的合理性、合规性进行分析、评审、决策的能力。
等级五	具备战略驱动的数据安全治理体系，实现数据安全决策、管理、技术实施、安全评估、安全审计的全链路闭环管理，具备灵活配置、有效协同的安全管理机制及内外部联动的数据安全协作机制。	具备智能匹配数据分类分级、数据应用场景及数据安全防护措施的数据安全管理策略，具备数据安全管理制度需求自动收集及研判、操作规程联动更新及审核、制度文件自动跟踪发布及其应用效果评价等智能化协同管理规程。	具备智能化管控技术体系，实现应用、系统、终端、网络等软硬件设备的运行数据与实时风险态势的联动分析，具备基于数据分类分级、适配不同场景的数据安全管控策略智能部署、动态更新及数据安全风险智能预判与处置能力。	熟练掌握国内外数据安全政策法规、技术标准与有关发展态势，具备预判或引领行业领域数据安全发展策略、体系建设方法、管理机制创新、技术应用创新或核心技术攻关等能力，具备本机构数据安全相关战略规划、体系架构、发展路径、制度规范等工作建议、工作方案的编制或审核能力，具备将数据安全能力建设与数字化转型、合规态势演进、数据价值利用等各方面发展需求进行融合建设的能力。

6 数据分类分级管理

6.1 目标

金融从业机构结合自身数据资源情况，建立数据资源识别梳理及数据分类分级工作机制，系统、全面开展数据资源分类分级管理工作，建立并维护本机构数据资源目录，明确基于数据分类分级的差异化安全管理需求。

6.2 能力要求

数据分类分级管理能力域各等级能力说明见表3。

表 3 数据分类分级管理能力域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	临时组建工作组、设立岗位或指派人员开展数据资源梳理及分类分级工作。	临时制定数据资源梳理、数据分类分级相关工作要求。	采用电子化方式实现数据资源目录及数据分类分级结果的维护。	了解数据资源及分类分级情况。
等级二	配备一定数量的岗位和人员，负责数据资源管理、数据分类分级工作。	具备数据资源管理和分类分级操作规程的基本要求及工作流程相关规定。	采用技术措施实现数据资源识别和梳理，辅助开展数据资源目录维护和数据分类分级。	掌握数据分类分级相关工作要求及工作流程，具备开展数据分类分级及数据资源目录维护的能力。
等级三	具备明确的数据资源管理、数据分类分级工作职责和部门，配备必要岗位和人员。	具备数据分类分级安全管理制度，细化数据资源目录编制和维护流程、分类分级原则和方法等安全管理细则和操作规程，明确数据资源目录的动态更新机制。	采用工具实现数据资源管理、运维及数据分类分级管理。	掌握数据分类分级工具的使用，具备系统实施数据分类分级、数据资源管理能力。
等级四	具备数据资源管理团队，承担数据资源识别梳理、数据目录建设和动态维护职责，负责数据分类分级相关策略、管理制度、操作规程的制定和更新，及数据分类分级的需求响应和组织实施工作。	—	采用自动化数据资源管理系统，实现数据自动识别与标记、数据资源目录的自动化维护。	具备对复杂数据应用场景数据资源识别和分类分级的研判能力和实施能力，及对数据资源目录、分类分级结果进行审核与校正的能力。
等级五	具备数据资源管理部门，负责组织和实施数据资源管理、数据分类分级策略和方案，智能识别、智能管控机制的建设、运维与优化等工作。	—	采用智能化数据资源管理系统，实现数据资源目录及分类分级结果的智能优化。	具备对数据资源智能化管理及分类分级系统的规则、模型、优化机制等内容的设计、审核、校正和实施的能力。

7 数据生命周期安全

7.1 数据收集

7.1.1 目标

金融从业机构通过加强数据收集活动的安全管理，提升数据收集过程数据安全性及相关操作行为的合法性、真实性和准确性，防范数据源伪造、数据泄露、数据篡改等安全风险。

7.1.2 能力要求

数据收集安全子域各等级能力说明见表4。

表 4 数据收集安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据收集安全管理工作要求。	采用电子化方式实现数据收集活动的记录和管理。	—
等级二	—	具备数据收集的基本原则、合法性、真实性、准确性及合约协议规范等安全管理基本要求、工作流程相关规定。	采用系统对接或应用接口等技术措施进行数据收集，具备身份鉴别、数据防篡改、数据脱敏等基本数据安全保护能力。	—

表4 数据收集安全子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级三	—	具备涵盖数据收集全过程的安全管理制度，细化数据收集需求、方式、目的、范围、审批、数据来源等安全管理细则和操作规程，具备针对数据提供方等第三方合作机构及相关数据收集活动的审批流程，明确第三方合作机构数据来源合法性及真实性、业务资质、数据安全保障能力等安全管理要求。	采用工具实现数据收集规则校验，例如数据源核验、关联信息交叉核验等，具备根据不同的数据收集需求进行收集规则及数据保护机制配置的能力。	—
等级四	—	—	具备数据收集需求、安全防护技术措施的自动配置和统一管理能力。	—
等级五	—	—	具备数据收集安全防护技术措施智能化配置、部署、调控的能力，实现数据收集安全防护技术措施风险智能预测及策略自主调整。	—

7.2 数据存储

7.2.1 目标

金融从业机构通过完善数据存储策略、配备存储安全技术等措施，加强数据存储过程的安全性，防范数据泄露、数据篡改、数据损毁等安全风险。

7.2.2 能力要求

数据存储安全子域各等级能力说明见表5。

表5 数据存储安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	临时组建工作组、设立岗位或指派人员开展数据库、数据中心等数据集中存储安全防护工作。	临时制定数据存储安全管理工作要求。	采用电子化方式实现存储策略和存储方式的记录、管理，并采用数据库系统自带的安全组件/服务实现数据安全。	了解数据库的操作规程，具备使用数据库管理系统进行安全配置的能力。
等级二	配备一定数量的岗位和人员，负责数据库、数据中心等数据集中存储安全防护工作。	具备数据存储介质安全管理、存储系统配置规则、存储期限设置、数据存储安全防护措施等基本要求及工作流程规定。	采用技术措施实现存储介质和存储系统的安全防护和运维管理，实现逻辑存储安全管控，具备敏感数据加密存储能力。	掌握存储介质、数据库、数据中心等数据安全防护工作要求及操作规程，具备执行数据存储安全日常运维能力。
等级三	具备明确的数据库、数据中心等数据集中存储安全防护工作责任部门，配备必要岗位和人员。	具备涵盖数据存储全过程的安全管理制度，细化存储介质访问规则、存储系统安全配置管理、访问控制规范、加密存储技术指南等管理细则和操作规程。	采用工具实现数据存储全过程管理和数据差异化保护，具备存储介质统一管理、异常操作发现等安全管理能力。	掌握存储介质、数据库等安全防护工具的调配策略和部署规程，具备根据不同业务场景和数据存储方式部署相应安全防护措施的能力。
等级四	设立跨区域、覆盖多元存储模式的存储安全协调小组，负责统筹协调数据安全存储工作、定期组织数	具备统一的覆盖本机构各存储节点和存储介质的安全管控策略、安全防护机制和运维流程。	具备系统化、自动化管控技术体系，实现数据存储技术措施统一调配、数据标识、关键字匹配、异常行为发	具备存储介质、数据库等数据存储安全防护情况分

表 5 数据存储安全子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级四	数据存储安全巡检。		现、动态令牌等技术措施。具备对存储系统安全配置、存储介质和数据访问控制的标准化、规范化和一致性管理能力。	
等级五	—	—	具备智能化管控技术体系，实现数据存储状态实时收集、故障风险预警、异常行为实时熔断、性能瓶颈预警等体系化管控，具备场景策略动态扩展与智能处置能力。	具备数据存储状态智能分析、安全防护规则、安全模型设计和建设的能力。
注：本文件所述敏感数据是指相关法律、行政法规、部门规章及行业标准规范中所述，一旦遭到篡改、破坏、泄露或非法获取、非法利用，可能对个人、组织合法权益或者对经济运行、社会稳定、公共利益等造成影响的数据，包括但不限于敏感个人信息、可能涉及商业秘密的客户经营信息、应当严格控制知悉范围的业务信息等。				

7.3 数据传输

7.3.1 目标

金融从业机构通过建立数据传输安全管理机制，采用数据加密、安全传输通道等技术措施，提升数据传输合规性和安全性的保障能力，防范数据泄露、数据篡改等安全风险。

7.3.2 能力要求

数据传输安全子域各等级能力说明见表6。

表 6 数据传输安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据传输安全管理工作要求。	采用电子化方式实现数据传输活动的记录和管理。	—
等级二	—	具备数据传输安全防护策略、传输通道安全实施方案等基本要求及工作流程规定。	采用技术措施实现通信方身份鉴别，具备敏感数据加密传输等技术能力。	—
等级三	—	具备涵盖数据传输全过程的安全管理制度，细化不同场景数据传输防护策略及其变更审核流程等安全管理细则和操作规程。	采用工具实现身份鉴别、数据防泄露、加密通道、数据加密等数据传输活动安全管控。	—
等级四	—	—	具备系统化、自动化管控技术体系，实现数据传输加密组件/服务的统一、规范管理和配置。	—
等级五	—	—	具备智能化管控技术体系，实现数据传输安全防护措施及审批结果的自动关联与智能化配置。	—

7.4 数据使用

7.4.1 目标

金融从业机构通过建立数据访问、查询、修改、展示、导出等数据使用安全管理机制，明确权限最小化原则，并采取身份鉴别、访问控制、数据脱敏、数据水印、文件加密、操作日志留存等技术措施，提升数据使用合规性和安全性，防范数据滥用、数据泄露、数据篡改等安全风险。

7.4.2 能力要求

数据使用安全子域各等级能力说明见表7。

表7 数据使用安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据使用安全管理相关工作要求。	采用电子化方式实现数据使用活动的记录和管理。	—
等级二	—	具备数据使用的权限管控、访问控制、审批授权等基本要求及工作流程。	采用技术措施实现数据使用安全防护，具备权限列表、黑/白名单、数据脱敏、页面保护、日志记录等数据使用安全管理能力，并具备对敏感数据导出活动的身份鉴别、权限管理、数据脱敏、文件加密等技术能力。	—
等级三	—	具备涵盖数据使用全过程的安全管理制度，细化不同场景的数据使用规则、权限管控策略、审批授权流程、数据脱敏、数据水印等安全管理细则和操作规程。	采用工具实现用户身份鉴别、访问控制、数据脱敏、数据水印、限制复制和打印等数据使用活动安全管控，具备差异化的安全防护措施配置能力及数据使用全过程日志记录能力。	—
等级四	—	—	具备系统化、自动化管控技术体系，实现访问控制组件或代理、动态数据脱敏、敏感数据展示与导出脱敏、数据溯源等技术防护，并具备用户身份鉴别与访问控制统一管理能力。	—
等级五	—	—	具备智能化管控技术体系，实现数据使用权限与控制措施的智能关联、配置、执行、审计与溯源。	—

7.5 数据加工

7.5.1 目标

金融从业机构通过建立数据加工安全管理机制，采取权限控制、数据脱敏、去标识化等技术措施，提升数据在清洗、转换、分析、挖掘、整合、汇聚融合等加工活动中的合规性和安全性，防范数据泄露、数据滥用等安全风险。

7.5.2 能力要求

数据加工安全子域各等级能力说明见表8。

表8 数据加工安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据加工安全管理工作要求。	采用电子化方式实现数据加工活动的记录和管理。	—
等级二	—	具备数据加工的安全防护策	采用技术措施实现数据加	—

表 8 数据加工安全子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级二	—	略、安全风险评估机制、审批授权等基本要求及工作流程。	工的流程控制和日志记录，具备对敏感数据、重要数据等数据加工活动的身份鉴别、权限管理、数据脱敏等技术能力。	—
等级三	—	具备涵盖数据加工全过程的安全管理制度，细化不同场景的数据加工防护策略、审批授权流程、数据加工方式等安全管理细则和操作规程。	采用工具实现统一的数据脱敏、去标识化等数据加工活动安全管控。	—
等级四	—	—	具备系统化、自动化管控技术体系，实现数据标识、敏感数据加工活动溯源等安全管控。	—
等级五	—	—	具备智能化管控技术体系，实现数据加工安全防护措施与审批结果的智能关联、配置与执行。	—

7.6 数据提供

7.6.1 目标

金融从业机构通过建立数据提供安全管理机制，明确数据提供方、数据接收方的数据安全相关权利和义务，及应具备的数据安全保护技术能力，并采取数据加密、数据脱敏等技术措施，提升数据提供的合规性和安全性，防范数据泄露、数据滥用、非法获取、非法利用等安全风险。

7.6.2 能力要求

数据提供安全子域各等级能力说明见表9。

表 9 数据提供安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据提供安全管理工作要求。	采用电子化方式实现数据提供的记录和管理。	—
等级二	—	具备数据提供的安全防护策略、安全风险评估机制、审批授权等基本要求及工作流程。	采用技术措施实现数据提供的流程控制和日志记录。	—
等级三	—	具备涵盖数据提供全过程的安全管理制度，细化不同场景数据提供防护策略、审核流程、安全规程等安全管理细则和操作规程。	采用工具实现访问控制、身份鉴别、数据加密、数据脱敏、数据水印等数据提供安全管控，具备相关安全防护策略及技术应用规则的一致性管控能力。	—
等级四	—	具备针对第三方合作机构及数据提供的审批流程，明确第三方合作机构资质、数据安全保障能力等安全管理要求。	具备系统化、自动化管控技术体系，实现数据提供及其安全防护措施与审批结果的联动管控。	—
等级五	—	—	具备智能化管控技术体系，实现数据提供安全防护措施与审批结果的智能关联、配置与执行。	—

7.7 数据委托处理

7.7.1 目标

金融从业机构通过建立数据委托处理安全管理机制，明确数据委托方、数据受托方的数据安全相关权利和义务及应具备的数据安全保护技术能力，并采取数据加密、数据脱敏等技术措施，提升数据委托处理的合规性和安全性，防范数据泄露、数据滥用、非法获取、非法利用等安全风险。

7.7.2 能力要求

数据委托处理安全子域各等级能力说明见表10。

表 10 数据委托处理安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据委托处理安全管理工作要求。	采用电子化方式实现数据委托处理的记录和管理。	—
等级二	—	具备数据委托处理的安全防护策略、安全风险评估机制、审批授权等数据安全基本要求及工作流程。	采用技术措施实现数据委托处理的流程控制和日志记录。	—
等级三	—	具备涵盖数据委托处理全过程的安全管理制度，细化不同场景数据委托处理安全防护策略、审核流程、安全规程等安全管理细则和操作规程。	采用工具实现数据加密、数据脱敏、数据水印、权限控制等数据委托处理安全管控，具备相关安全防护策略及技术应用规则的一致性管控能力。	—
等级四	—	具备针对第三方合作机构及数据委托处理活动的审批流程，明确第三方合作机构资质、数据安全保障能力等安全管理要求。	具备系统化、自动化管控技术体系，实现数据委托处理及其安全防护措施与审批结果的联动管控。	—
等级五	—	—	具备智能化管控技术体系，实现数据委托处理安全防护措施与审批结果的智能关联、配置与执行。	—

7.8 数据公开披露

7.8.1 目标

金融从业机构通过建立数据公开披露安全管理机制，并采取数据脱敏、数据水印等技术措施，提升数据公开披露的安全性，确保在指定渠道公开信息，防范数据泄露、数据篡改等安全风险。

7.8.2 能力要求

数据公开披露安全子域各等级能力说明见表11。

表 11 数据公开披露安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据公开披露安全管理工作要求。	采用电子化方式实现数据公开披露的记录和管理。	—
等级二	—	具备数据公开披露审批流程、数据公开披露合法性、数据真实性审核等数据安全基本要求及工作流程。	采用技术措施实现数据公开披露的流程控制及日志记录。	—
等级三	—	具备涵盖数据公开披露全过	采用工具实现数据脱敏、数	—

表 11 数据公开披露安全子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级三	—	程的安全管理制度，细化各类数据和披露场景的审批流程、数据脱敏方式、公开期限、数据防篡改、防爬取等安全管理细则和操作规程。	据水印、防篡改等数据公开披露安全管控，具备相关数据防爬取管控能力。	—
等级四	—	—	具备系统化、自动化管控技术体系，实现对公开披露数据的智能敏感筛查、实时监测、异常操作告警、紧急撤回/屏蔽及数据溯源。	—
等级五	—	—	—	—

7.9 数据删除

7.9.1 目标

金融从业机构通过建立数据删除安全管理机制，并采取数据删除有效性验证等技术措施，确保数据处于不可被检索、访问的状态，防范数据滥用、数据泄露等安全风险。

7.9.2 能力要求

数据删除安全子域各等级能力说明见表12。

表 12 数据删除安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据删除安全管理工作要求。	采用数据库等系统和设备自带功能实现数据删除处理，并采用电子化方式实现数据删除活动的记录和管理。	—
等级二	—	具备数据删除的基本原则、触发情形、删除流程、操作记录等数据安全基本要求及工作流程。	采用技术措施实现数据删除有效性验证，确保数据处于不可被检索、访问的状态。	—
等级三	—	具备涵盖数据删除全过程的安全管理制度，细化删除方式、审批流程等安全管理细则和操作规程。	采用工具实现数据删除操作监测和有效性验证。	—
等级四	—	—	—	—
等级五	—	—	—	—

7.10 数据销毁

7.10.1 目标

金融从业机构通过建立数据销毁安全管理机制，对数据库、服务器、存储系统、终端设备和存储介质等采用覆写、消磁、焚毁等方法，确保数据不可恢复，防范因介质丢失导致的数据泄露风险。

7.10.2 能力要求

数据销毁安全子域各等级能力说明见表13。

表 13 数据销毁安全子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据销毁安全管理工作要求。	采用电子化方式实现数据销毁的记录和管理。	—
等级二	—	具备数据销毁的基本原则、触发情形、销毁流程、过程记录等数据安全基本要求及工作流程。	采用技术措施实现数据销毁,具备对存储敏感数据介质的销毁能力。	—
等级三	—	具备涵盖数据销毁全过程的安全管理制度,细化销毁方式、过程监督与记录等安全管理细则和操作规程。	采用工具实现数据销毁,具备数据不可被恢复的销毁能力及数据销毁效果验证能力。	—
等级四	—	—	—	—
等级五	—	—	—	—

8 数据安全运营保障

8.1 权限安全管理

8.1.1 目标

金融从业机构通过用户授权、身份鉴别、访问控制等技术措施和管理机制,在数据处理活动各环节和数据应用过程构建可靠、有效的权限安全管理机制,对数据、终端、应用、系统的访问和使用等操作权限进行授权审批、用户身份识别和验证等安全管理,确保仅授权主体对其权限内的数据资源进行合法操作,防范因未授权访问、越权访问导致的数据泄露、数据篡改、数据滥用等安全风险。

8.1.2 能力要求

权限安全管理子域各等级能力说明见表14。

表 14 权限安全管理子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定用户权限管理相关工作要求。	采用电子化方式实现用户角色及权限的配置和管理。	了解身份鉴别与访问控制基本工作要求,具备执行常规用户权限配置和管理的能力。
等级二	—	具备系统、数据资源身份鉴别与访问控制的基本要求及工作流程。	采用技术措施实现身份鉴别与访问控制。	掌握身份鉴别与访问控制工作要求及工作流程,具备实施单一身份鉴别技术及权限配置策略的能力。
等级三	—	具备身份鉴别与访问控制相关管理制度,明确权限管控策略机制、权限授予及变更的审批流程等安全管理细则和操作规程。	采用工具实现多因素认证等身份鉴别、数据资源及用户统一纳管,具备涵盖权限的申请、审批、授权等全过程的权限安全管控能力,实现适配不同应用场景的访问控制策略及技术配置。	掌握身份鉴别与访问控制应用场景及其安全管理要求,具备用户权限配置策略建设和多因素身份认证技术实施能力,具备根据场景配置和实施相应强度访问控制策略的能力。
等级四	—	具备精细化的权限管理制度与流程,明确权限分配与业务角色、数据分类分级的动态关联和自动校验机制,及特权账号异常操作实时监测与应急	具备系统化、自动化管控技术体系,实现用户权限、身份鉴别技术及访问控制策略的自动识别与配置,具备自动化密码管理、权	统筹权限管控体系的建设和深入理解整体数据架构、数据存储及数据流向,具备权限安全管理相关技术实施、系统配置、安全

表 14 权限安全管理子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级四	—	响应流程。	限校验、高风险下的权限阻断等能力。	加固等能力。
等级五	—	具备根据权限管理制度落地应用效果、风险态势、新技术应用等情况进行权限管理策略智能调优的机制。	具备智能化管控技术体系，实现访问控制策略的智能调配和优化，具备基于应用场景的权限配置智能调控、密码动态管理等智能化权限管控能力。	—

8.2 数据备份与恢复

8.2.1 目标

金融从业机构通过构建完善的数据备份与恢复体系，确保数据在遭遇丢失、损毁、破坏或系统故障等意外情况时，能够及时、准确地恢复数据，保障数据可用性、业务连续性和稳定性。

8.2.2 能力要求

数据备份与恢复子域各等级能力说明见表15。

表 15 数据备份与恢复子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	临时组建工作组、设立岗位或指派人员开展数据备份与恢复工作。	临时制定数据备份与恢复工作要求。	采用电子化方式实现数据备份与恢复活动的记录和管理。	了解数据备份与恢复基本工作要求，具备执行简单数据备份与恢复操作的能力。
等级二	配备一定数量的岗位和人员，负责数据备份与恢复工作。	具备数据备份与恢复的基本要求及工作流程。	采用技术措施实现数据集中备份管理，具备建立本地灾备中心、配置备份策略、敏感数据加密备份的能力。	掌握数据备份与恢复工作要求及工作流程，具备配置常规备份任务、执行数据恢复演练、备份日志分析及故障定位的能力。
等级三	具备明确的数据备份与恢复责任部门，配备必要岗位和人员。	具备数据备份与恢复相关管理制度，细化结合数据分类分级的备份恢复策略、备份数据可恢复性验证方式、应急预案等安全管理细则和操作流程。	采用工具实现数据的同城双活和异地容灾备份管理，实现数据的多重备份和异地同步，具备备份数据可恢复性的自动验证能力。	掌握数据备份与恢复技术架构，具备设计跨地域备份策略、熟练操作容灾切换流程、备份介质管理、数据恢复成功率分析的能力。
等级四	具备数据安全备份与恢复工作团队，负责数据备份与恢复工作计划、备份策略、实施方案等材料的编制、实施、更新及维护，承担数据备份与恢复相关安全演练工作的组织和执行。	具备常态化的数据备份与恢复应急演练制度及流程，并根据演练效果对数据备份与恢复策略进行量化评价和动态调整的机制。	采用数据备份与恢复管理系统，实现数据备份与分类分级的动态关联及自动校验，具备备份数据的统一管理、备份任务的集中监控告警、备份系统基础故障处置或自动恢复等能力。	掌握数据备份与恢复管理系统运维能力，具备基于业务需求和资源状况优化备份策略与资源配比的能力，具备较复杂业务场景的容灾方案设计建议、跨部门协调组织恢复演练、分析备份有效性并提出改进建议的能力。
等级五	—	—	具备智能化数据备份与恢复技术体系，实现根据备份效果进行备份策略智能优化及备份数据有效性智能验证，具备数据备份的场景、数量、频率等定期自动化统计和分析的能力。	理解业务连续性与数据安全的关系，具备体系化规划和持续优化备份恢复策略的能力，具备主导或深度参与行业数据备份与恢复相关规范制度的编写、分析评估备份与恢复体系

表 15 数据备份与恢复子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级五	—	—		的整体有效性、效率及风险隐患，提出前瞻性的韧性提升建议的能力，并具备跨团队知识共享与指导的能力。

8.3 新技术应用风险防控

8.3.1 目标

金融从业机构通过建立新技术在本机构落地应用过程的数据安全管理机制，健全数据安全领域新技术应用的风险识别和测试评估流程，保障新技术在数据生命周期全过程应用的合规性和安全性，有效防范新技术应用风险。

8.3.2 能力要求

新技术应用风险防控子域各等级能力说明见表16。

表 16 新技术应用风险防控子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定新技术应用安全要求。	采用电子化方式实现新技术应用需求及应用情况的记录和管理。	了解相关领域新技术应用及数据安全保护知识。
等级二	—	具备新技术应用数据安全基本要求及工作流程。	采用技术措施实现新技术应用的数据安全风险识别与防护。	掌握新技术应用数据安全要求，具备使用通用工具开展安全测试与防护的能力。
等级三	—	具备新技术应用风险防控相关管理制度，细化涵盖新技术应用全过程的数据安全评价方式、应用场景控制、风险识别、风险处置、监督管理方法等安全管理细则和操作规程。	采用工具实现新技术应用全过程的数据安全需求分析、风险评估、措施配置等安全管控。	掌握安全测试工具的使用，具备研判新技术应用数据安全风险并制定应对措施的能力。
等级四	—	具备新技术应用风险跟踪、威胁情报分析、动态风险预警、风险防控策略的调整的机制。	具备系统化、自动化管控技术体系，实现新技术应用的统一管理及相应风险防范工具的自动匹配。	具备分析新技术发展趋势及熟练使用自动化安全工具进行风险防控的能力。
等级五	—	—	—	具备新技术研究和应用、核心技术攻关、技术风险态势分析与处置等能力。
注：本文件的新技术是指人工智能、量子计算等，在基础原理、实现范式与应用价值等方面呈现巨大潜力、高速发展态势，但在技术实践和行业应用方面尚未经过广泛、深入验证的前沿新兴科技。				

8.4 数据安全风险监测

8.4.1 目标

金融从业机构通过建立数据安全风险监测机制，全面监控和分析数据生命周期全过程的数据处理活动，发现、干预或处置数据异常操作、数据滥用等安全风险，降低数据安全事件的发生概率和数据安全风险的影响。

8.4.2 能力要求

数据安全风险监测子域各等级能力说明见表 17。

表 17 数据安全风险监测子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	—	临时制定数据安全风险监测工作要求。	采用电子化方式开展数据安全风险监测活动的记录和管理。	熟悉数据安全风险监测相关工作要求及工作流程。
等级二	—	具备覆盖关键和重要业务系统或应用场景、办公和业务终端及第三方合作机构的数据安全风险监测基本要求及工作流程。	采用技术措施实现终端标识、敏感数据识别、病毒检测，具备对关键和重要业务系统或应用场景、办公和业务终端的风险监测能力。	具备数据安全风险监测技术措施的配置和实施能力。
等级三	—	具备数据安全风险监测管理制度，明确覆盖数据生命周期全过程的风险监测要点、风险处置流程、安全事件分级响应机制、内外部协同机制、风险处置时效要求等安全管理细则和操作规程。	采用工具实现终端管控、数据防泄露、异常行为监测、源代码扫描、数据调用链分析，具备基于数据分类分级且适配不同场景的数据加密、数据脱敏、数据水印等数据安全措施有效性监测及敏感数据泄露等高风险防控能力，实现覆盖数据生命周期全过程及办公、业务终端、应用、系统的实时风险监测和预警。	掌握数据安全风险监测操作规程，具备风险监测工具的选型、配置和部署能力，具备开展风险告警内容分析和处置的能力。
等级四	—	—	具备系统化、自动化数据安全风险监测技术体系，实现涵盖生产、研发、测试等环境数据安全管控要素的数据安全风险监测及安全态势感知，具备多源实时数据的统一聚合与分析、内外部数据安全风险的监测预警及自动化处置能力。	具备对数据安全风险、告警等信息的跟踪溯源、风险研判的能力，具备组织协调相关部门及人员协同开展风险分析和风险处置的能力。
等级五	—	—	具备智能化数据安全风险评估系统技术体系，实现风险监测策略、规则和模型的自动构建及智能优化。	具备智能化风险防控策略和规则制定，及风险识别、分析和处置相关智能算法和模型建设与部署的能力。

8.5 数据安全风险评估

8.5.1 目标

金融从业机构通过开展数据安全风险评估，掌握本机构数据安全保护现状，识别数据安全工作中存在的问题与不足，发现数据资源面临的安全风险，并将评估结果与制度完善、技术升级、资源配置紧密联动，持续提升数据安全保护能力，降低数据非法获取、数据滥用等安全风险。

8.5.2 能力要求

数据安全风险评估子域各等级能力说明见表18。

表 18 数据安全风险评估子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	临时组建工作组、设立岗	临时制定数据安全风险评估	采用电子化方式实现数据	了解整体数据安全工作情

表 18 数据安全风险评估子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	位或指派人员开展数据安全风险评估工作。	工作要求。	安全风险评估活动的记录和管理。	况及数据安全风险评估工作要求。
等级二	配备一定数量的岗位和人员，负责数据安全风险评估工作。	具备数据安全风险评估基本要求及工作流程相关规定。	采用技术措施开展数据安全风险评估。	掌握数据安全风险评估工作要求、工作流程及安全检查工具的使用，具备识别关键节点数据安全风险的能力。
等级三	具备明确的数据安全风险评估责任部门，配备必要岗位和人员。	具备涵盖关键和重要业务系统或应用场景、重要数据、敏感数据等的数据安全风险管理制度，细化数据安全风险评估的工作内容、评估流程、评估频率、评估报告、报送方式等安全管理细则和操作规程。	采用漏洞扫描设备、测评组件/服务等工具实现覆盖数据生命周期全过程的数据安全风险评估。	掌握数据安全风险评估工具的使用，具备数据安全风险问题发现和风险评估的能力。
等级四	具备专业的数据安全风险评估团队，承担数据安全风险评估工作相关管理制度、操作规程的编制，负责组织和实施数据安全风险评估工作。	具备涵盖数据生命周期全过程的数据安全风险管理制度体系，及数据安全风险评估制度体系落地应用效果量化评价机制和动态调整机制。	具备系统化、自动化数据安全风险评估技术体系，实现评估需求与评估方案的自动匹配及相应评估报告的自动生成。	掌握数据处理活动可能面临的风险，具备统筹复杂场景数据安全风险评估需求、制定风险评估工作方案和对安全风险情况研判的能力，具备对评估报告进行审核与校对的能力。
等级五	—	—	具备智能化数据安全风险评估技术体系，实现数据安全风险的智能研判与处置、评估需求与评估方案的智能匹配，具备评估策略、评估方案的智能设计与优化的能力。	具备统筹数据安全风险评估工作，并对评估规则、评估模型、评估报告等进行设计、审核和持续改进的能力。

8.6 数据安全合规审计

8.6.1 目标

金融从业机构通过开展数据安全合规审计，审视本机构数据处理活动的合法合规性，评价数据安全管理制度、的执行情况，并对数据安全威胁或数据安全事件进行追溯和分析，促进数据安全工作的及时改进和完善。

8.6.2 能力要求

数据安全合规审计子域各等级能力说明见表19。

表 19 数据安全合规审计子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	临时组建工作组、设立岗位或指派人员开展数据安全合规审计工作。	临时制定数据安全合规审计工作要求。	采用电子化方式实现数据安全合规审计活动的记录和管理。	了解数据安全合规整体工作情况及数据安全合规审计工作要求。
等级二	配备一定数量的岗位和人员，负责数据安全合规审计工作。	具备数据安全合规审计的基本要求及工作流程。	采用技术措施实现数据处理活动关键节点的操作日志记录。	熟悉数据安全合规审计相关工作要求及工作流程，具备日志审计的能力。
等级三	具备明确的数据安全合规审计工作责任部门，配备	具备数据安全合规审计管理制度，细化数据生命周期全过	采用审计组件/服务、审计系统等工具，实现覆盖数据	掌握数据应用场景及数据安全审计相关工作要求及

表 19 数据安全合规审计子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级三	必要岗位和人员。	程的数据安全合规审计频率、不同场景的审计策略、审计内容等安全管理细则和操作规程。	生命周期全过程的日志记录统一管理与分析。	工作流程，具备数据安全合规审计相关工作技能，并具备对审计发现的问题进行分析和处理的能力。
等级四	具备专业的数据安全审计团队，承担数据安全审计工作管理制度、操作规程的编制，负责组织和实施数据安全审计工作。	具备涵盖数据生命周期全过程的数据安全审计制度体系，及数据安全审计制度体系落地应用效果量化评价机制和动态调整机制。	具备系统化、自动化数据安全审计技术体系，实现数据的异常访问等操作风险的量化统计及安全合规要求的自动匹配，具备异常情况自动识别与发现的能力。	具备复杂数据应用场景的安全审计需求研判和工作方案制定能力，具备相关报告审核与校对能力。
等级五	—	—	具备智能化数据安全审计技术体系，实现数据生命周期全过程智能审计与审计策略智能优化，具备审计问题的智能化反馈及跟踪能力。	具备对智能化审计系统的审计规则、审计模型、审计报告等的设计、审核、校正等能力。

8.7 应急响应与事件处置

8.7.1 目标

金融从业机构通过建立数据安全事件应急响应、处置及报送机制，确保在发生数据泄露、篡改、损毁或滥用等安全事件时，及时响应，快速识别定位问题、有效控制事件影响、及时处置并合规上报，最大限度降低数据安全事件危害。

8.7.2 能力要求

数据安全应急响应与事件处置子域各等级能力说明见表20。

表 20 数据安全应急响应与事件处置子域各等级能力说明

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级一	临时组建工作组、设立岗位或指派人员开展数据安全应急响应与处置工作。	临时制定数据安全应急响应与处置工作要求。	采用电子化方式实现数据安全应急响应与处置活动的记录和管理。	熟悉数据安全应急工作要求及工作流程。
等级二	配备一定数量的岗位和人员，负责数据安全应急响应与处置工作。	具备数据安全应急响应与事件处置的基本要求及工作流程。	采用技术阻断、数据恢复等技术措施实现关键和重要业务系统或应用场景的数据安全应急响应与处置，具备关键和重要业务系统或应用场景的数据溯源、日志记录能力。	具备使用基础工具进行数据安全应急响应与处置的能力。
等级三	具备明确的数据安全应急响应与处置责任部门，配备必要岗位和人员，负责组织管理、科技、业务相关部门协同实施数据安全应急响应与处置工作。	具备数据安全应急响应与处置相关管理制度，细化覆盖数据生命周期全过程的应急演练方案、频率、事件分级、不同事件处置流程、内外部协同机制、专项应急预案等安全管理细则和操作规程。	采用沙盒、攻防系统等工具实现覆盖数据生命周期全过程的数据安全应急演练，具备数据处理活动关键信息及关键节点数据流动情况的记录能力。	掌握数据安全应急预案与应急演练操作规程，具备使用数据溯源技术进行事件分析、排查的能力。
等级四	具备专业的数据安全应急响应与处置团队，承担数据安全应急响应与处置工作管理制度、操作规程的编制，负责组织和实施数	具有覆盖机构总部及下属机构、子公司的数据安全应急响应专项制度或专项应急预案，细化事件定级、数据真实性核验、数据溯源排查、风险控制、	具备系统化、自动化数据安全应急响应与处置技术体系，实现与数据安全风险监测系统联动，具备数据溯源信息标记、溯源数据自动分	具备全局视角分析和处置数据安全风险事件的能力，具备组织数据安全突发事件应急演练及持续优化应急处置流程的

表 20 数据安全应急响应与事件处置子域各等级能力说明（续）

数据安全能力等级	能力维度			
	组织建设	制度流程	技术能力	人员能力
等级四	据安全应急响应与处置工作。	监管报告、告知受影响主体、定期开展应急演练等实施规范和细则。	析与快速定位等能力。	能力。
等级五	—	—	具备智能化数据安全应急响应与处置技术体系，实现数据安全事件智能溯源，具备自动化、可视化的数据流转链路生成能力及智能化分析能力。	具备智能化数据安全应急响应、处置策略和规则制定能力，具备数据安全事件分析、处置相关智能算法和模型的建设与部署能力。

参 考 文 献

- [1] GB/T 45389—2025 数据安全技术 数据安全评估机构能力要求
 - [2] GB/T 45574—2025 数据安全技术 敏感个人信息处理安全要求
 - [3] GB/T 45577—2025 数据安全技术 数据安全风险评估方法
 - [4] JR/T 0171—2020 个人金融信息保护技术规范
 - [5] JR/T 0197—2020 金融数据安全 数据安全分级指南
 - [6] JR/T 0218—2021 金融业数据能力建设指引
 - [7] JR/T 0223—2021 金融数据安全 数据生命周期安全规范
 - [8] 中华人民共和国个人信息保护法
 - [9] 中华人民共和国数据安全法
 - [10] 中华人民共和国网络安全法
 - [11] 网络数据安全条例
-